Cybersecurity Daily Newsletter

Vol. 006 | 2026-10-25 09:00 WIB

Top 5 Highlights

• BlackX UEFI bootkit exploits Baton Drop flaw to bypass Secure Boot

• Brotli Decoder Flaw Behind Node.js RCE Also Affects Bun, Python and Other Widely Used Software

• Leaked LiteLLM Master Key Let Attackers Steal GitHub Tokens and Hijack Release Pipeline

• [+24h Old] Researchers Push Over 2 Million Updates to Remotely Disable Popcorn Time Updater That Could Fuel a Botnet

• [+24h Old] CISA Flags Two Actively Exploited Critical Flaws in Collabora Online and Arista VeloCloud

Threat Intelligence (10)

01. [+24h Old] Researchers Push Over 2 Million Updates to Remotely Disable Popcorn Time Updater That Could Fuel a Botnet

Between November 2025 and March 2026, the Dutch security firm Eye Security pushed more than 2 million updates to computers it did not own to switch off a background updater that it said could have allowed an outsider to take over the machine. The updater belongs to Time4Popcorn, an abandoned copy of Popcorn Time, a free app that streamed pirated films and T…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/10/researchers-push-over-2-million-updates.html

02. [+24h Old] Cyber insurance providers adapt to evolving threat landscape

Cyber insurance has evolved from a niche product into a critical component of organizational security strategies as providers implement stricter requirements to combat sophisticated threats based on information published by Dark Reading.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.scworld.com/brief/cyber-insurance-providers-adapt-to-evolving-threat-landscape

03. [+24h Old] New York Knicks use fake championship ring offer in phishing test

The New York Knicks organization recently conducted a phishing test by sending employees emails promising free championship rings to evaluate staff awareness of cybersecurity threats, as first reported by Ars Technica.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.scworld.com/brief/new-york-knicks-use-fake-championship-ring-offer-in-phishing-test

04. [+24h Old] Russian hackers collaborate on destructive cyberattack against Ukrainian logistics firm

A destructive data-wiping attack against a Ukrainian logistics company was carried out through a strategic partnership between the Russian state-sponsored group Sandworm and another threat actor, as first reported by The Hacker News.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.scworld.com/brief/russian-hackers-collaborate-on-destructive-cyberattack-against-ukrainian-logistics-firm

05. [+24h Old] Microsoft Teams to get AI-powered, context-aware phishing detection

Microsoft has announced plans to add AI-powered phishing detection to Teams messages starting in early November 2026. […]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.bleepingcomputer.com/news/microsoft/microsoft-teams-to-get-ai-powered-context-aware-phishing-detection/

06. [+24h Old] AI Tools Are Generating Massive Attacks for Little Cost

One campaign targets 105 sites using open-weight models; in another, public models gained full domain control for $12. Cyber-defense will have to change.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.darkreading.com/cybersecurity-operations/ai-tools-massive-attacks-little-cost

07. [+24h Old] Dual BIOS: The laptop security feature SMBs don’t know they need

Every security checklist starts with the basics: strong passwords, multifactor authentication, spotting phishing, and keeping software up to date. All four protect what happens after a laptop starts. But some attackers are more focused on what happens before. That’s the domain of the BIOS, the first code that runs when a laptop powers on. It checks the hard…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.csoonline.com/article/4239779/dual-bios-the-laptop-security-feature-smbs-dont-know-they-need.html

08. [+24h Old] Resident Evil maker Capcom warns of phishing after 11.7 million records exposed

Exposed email addresses could put CAPCOM ID users at risk of phishing. Passwords were also changed without permission on 196 accounts.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.malwarebytes.com/blog/data-breaches/2026/10/resident-evil-maker-capcom-warns-of-phishing-after-11-7-million-records-exposed

09. [+24h Old] Infostealer riding the AI Train

Key Points Introduction Infostealers commonly target browser passwords, session cookies, and cryptocurrency wallets. This malware combines those established capabilities with dedicated collection routines for AI applications and development tools. Its targets include Claude, ChatGPT Desktop, Codex, Cursor, Windsurf, and GitHub Copilot, alongside cloud crede…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://research.checkpoint.com/2026/infostealer-riding-the-ai-train/

10. [+24h Old] Russia-Linked Hackers Used New Mesh Network Backdoor in Destructive Ukraine Attack

The Russian state-sponsored hacking group Sandworm teamed up with another threat actor to carry out a destructive wiping attack targeting a Ukrainian logistics company last year. According to ESET, the attack involved UAC-0099 (aka Earth Sirrush) obtaining initial access to the target on July 16, 2025, via a spear-phishing email bearing a malware-laced atta…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://thehackernews.com/2026/10/russian-linked-hackers-used-new-mesh.html

Latest Vulnerabilities (10)

01. BlackX UEFI bootkit exploits Baton Drop flaw to bypass Secure Boot

A new UEFI bootkit named BlackX, deployed in an espionage campaign in early 2026, exploited the old Baton Drop vulnerability to bypass Secure Boot and load a malicious driver designed to interfere with security solutions from Kaspersky and Avast. […]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/blackx-uefi-bootkit-exploits-baton-drop-flaw-to-bypass-secure-boot/

02. Brotli Decoder Flaw Behind Node.js RCE Also Affects Bun, Python and Other Widely Used Software

A memory-corruption flaw in Google's Brotli decoder sits in many programs that unpack Brotli-compressed data, among them Bun, the Python Brotli and brotlicffi packages, and Envoy proxies set up to decompress Brotli. Tracked as CVE-2026-111497, the flaw allows crafted compressed data to overwrite past the end of a buffer and corrupt a program's memory, poten...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/brotli-decoder-flaw-behind-nodejs-rce.html

03. [+24h Old] CISA Flags Two Actively Exploited Critical Flaws in Collabora Online and Arista VeloCloud

The U.S. Cybersecurity and Infrastructure Security Agency (CISA) on Friday added two vulnerabilities impacting Collabora Online Built-in CODE Server and Arista VeloCloud Orchestrator (VCO) to its Known Exploited Vulnerabilities (KEV), citing reports of active exploitation in the wild. The critical-severity vulnerabilities are listed below - CVE-2026-110447...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/cisa-flags-two-actively-exploited.html

04. [+24h Old] How to Identify Compromised eMudhra Certificates With Qualys (CVE-2026-111943 and CVE-2026-111944)

Executive Summary A critical certificate authority incident disclosed on October 17, 2026, impacts eight eMudhra intermediate CA certificates. A flaw in the key generation process could allow attackers to recover private keys and issue fraudulent TLS or code-signing certificates. The affected intermediates have been revoked and blocked by major platform ven...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://blog.qualys.com/product-tech/2026/10/23/how-to-identify-compromised-emudhra-certificates-with-qualys-cve-2026-111943-and-cve-2026-111944

05. [+24h Old] Japan calls for cybersecurity task force to combat AI-driven threats

The Liberal Democratic Party in Japan has requested the government establish a dedicated cybersecurity task force to bolster national defenses against an increasing wave of AI-powered attacks, based on information published by IT Pro.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/japan-calls-for-cybersecurity-task-force-to-combat-ai-driven-threats

06. [+24h Old] Senior CISA official departs agency amid vulnerability tracking challenges

Lindsey Cerkovnik, a senior official at the Cybersecurity and Infrastructure Security Agency, is leaving her position this week after nearly six years of service, based on information published by Nextgov.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/senior-cisa-official-departs-agency-amid-vulnerability-tracking-challenges

07. [+24h Old] Abandoned Popcorn Time app exposed millions of devices to RCE attacks

Researchers remotely disabled a vulnerable updater in the abandoned Time4Popcorn app, a fork of the Popcorn Time BitTorrent client, closing a security flaw that could have allowed attackers to execute malicious code with elevated privileges on millions of computers. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/abandoned-popcorn-time-app-exposed-millions-of-device-to-rce-attacks/

08. [+24h Old] (Reliable)? php2shell exploitability, (Fri, Oct 23rd)

Yesterday everyone was running around like crazy (me included :) because of the php2shell vulnerability.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://isc.sans.edu/diary/rss/33452

09. [+24h Old] Threat Brief: Critical Vulnerabilities in PHP: CVE-2026-109618, CVE-2026-109619 (Updated October 23)

CVE-2026-109618 and CVE-2026-109619 are Critical vulnerabilities in PHP, a scripting language used globally for web servers and CMS systems. The post Threat Brief: Critical Vulnerabilities in PHP: CVE-2026-109618, CVE-2026-109619 (Updated October 23) appeared first on Unit 42 .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://unit42.paloaltonetworks.com/cve-2026-109618-cve-2026-109619/

10. [+24h Old] BlackX UEFI Bootkit Bypasses Secure Boot on Patched Windows Systems Missing Revocations

Diplomatic organizations in Central Asia have been targeted by a sophisticated new Unified Extensible Firmware Interface (UEFI) bootkit called BlackX. The activity, which singled out diplomatic entities in Tajikistan, Uzbekistan, and Turkmenistan in early 2026, is suspected to be orchestrated by a China-linked state-sponsored hacking group known as APT41, K...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://thehackernews.com/2026/10/blackx-uefi-bootkit-bypasses-secure.html

Data Breach & Cybercrime (10)

01. Leaked LiteLLM Master Key Let Attackers Steal GitHub Tokens and Hijack Release Pipeline

LiteLLM on Friday revealed that an Agent Platform master key accidentally published to a public GitHub repository in late May 2026 ultimately allowed the threat actor to push a malicious version of the popular Python package. "On May 27, 2026, a configuration file was committed to the public LiteLLM-Labs/lite-harness repository which inadvertently contained...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/leaked-litellm-master-key-let-attackers.html

02. [+24h Old] Trust Is Not What It Seems - And Fraudsters Are Counting on It

Threat actors don't need to rely on malware to breach organizations anymore. They're simply calling help desks and politely asking for access, with a little help from artificial intelligence.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/cyber-risk/trust-is-not-what-it-seems-and-fraudsters-are-counting-on-it

03. [+24h Old] Exposed Infrastructure Reveals How Ransomware Affiliates Used AI Agents to Execute Intrusions

Cybersecurity researchers have discovered an artificial intelligence (AI)-driven intrusion ecosystem run by affiliates of the INC and The Gentlemen ransomware groups. Central to the operation is an "Autonomous Red Team Kill Chain Framework" referred to as Phantom. The threat actor is assessed to be Russian-speaking and functions both as an intrusion and dat…

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://thehackernews.com/2026/10/exposed-infrastructure-reveals-how.html

04. [+24h Old] Quest Diagnostics confirms data breach exposed patient records

American clinical laboratory company Quest Diagnostics disclosed that patient records have been exposed after a threat actor gained unauthorized access to its Quanum LSM system. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/quest-diagnostics-confirms-data-breach-exposed-patient-records/

05. [+24h Old] Meta hit with $25 billion fine for illegally sharing user data

A judge in New Mexico has fined Meta $25 billion for its flouting of data privacy laws between 2010 and 2021, including its controversial passing of data to Cambridge Analytica…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.csoonline.com/article/4239754/meta-hit-with-25-billion-fine-for-illegally-sharing-user-data-2.html

06. [+24h Old] In Other News: Tor Exit Relays Hijacked, Banks Spot Rogue AI Agents, Self-Rebuilding macOS Ransomware

Noteworthy stories that might have slipped under the radar: Russia’s APT28 hit NATO defense firms, PingCAP source code stolen, ShinyHunters negotiator probe. The post In Other News: Tor Exit Relays Hijacked, Banks Spot Rogue AI Agents, Self-Rebuilding macOS Ransomware appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.securityweek.com/in-other-news-tor-exit-relays-hijacked-banks-spot-rogue-ai-agents-self-rebuilding-macos-ransomware/

07. [+24h Old] Hackers Breach Enterprise Firewalls and VPNs, Exposing Over 70,000 Credentials

Cybersecurity researchers have disclosed details of a large-scale campaign that has targeted exposed network edge devices such as Fortinet FortiGate and Palo Alto Networks GlobalProtect firewalls. "Artifacts from this investigation also indicate that operators in this campaign have obtained access to numerous organizations worldwide, and have attempted to f…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/10/hackers-breach-enterprise-firewalls-and.html

08. [+24h Old] Microsoft 365 accounts compromised at 79 organizations, no passwords needed

An attacker who spent ten weeks replaying stolen Microsoft 365 sign-in sessions broke into email accounts at 79 organizations and used hidden inbox rules to keep victims from seeing parts of their own mail, according to Huntress. The researchers tracked the campaign between July 14 and September 22, 2026, counting 497 successful sign-ins and more than 200,0…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/10/23/microsoft-365-accounts-stolen-sessions/

09. [+24h Old] Gaming Giant Capcom Confirms Data Breach Exposed Users' Personal Information

Japanese video games giant Capcom confirmed unauthorized access to its online account system

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/capcom-confirms-data-breach/

10. [+24h Old] Attacks on Tech Firms Behind Most Third-Party Data Breach Victims

Kroll found that 69% of data breach victims in the past year were affected by a third-party breach, with attacks on tech companies the most common cause

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.infosecurity-magazine.com/news/tech-third-party-breach-victims/